

OPTIMIZACIÓN DE REGLAS DE FIREWALL BASADA EN LOGS

Javier Barreto Rico

2º Sistemas Microinformáticos y redes

15/05/2026

CONTEXTO Y MOTIVACIÓN

El proyecto surge a partir de una situación observada durante las prácticas en empresa

Parte de un entorno real, donde el firewall protege la red corporativa y sus servicios

Con el tiempo, las reglas pueden acumular excepciones y permisos “por si acaso”

Esto puede generar reglas demasiado abiertas y aumentar la superficie de ataque

Por ello, resulta necesario revisar la política con datos reales obtenidos de los logs

Objetivo: acercarse al principio de mínimo privilegio sin romper servicios



OBJETIVOS DEL PROYECTO

Objetivo general

Mejorar la seguridad del firewall mediante el análisis de sus logs

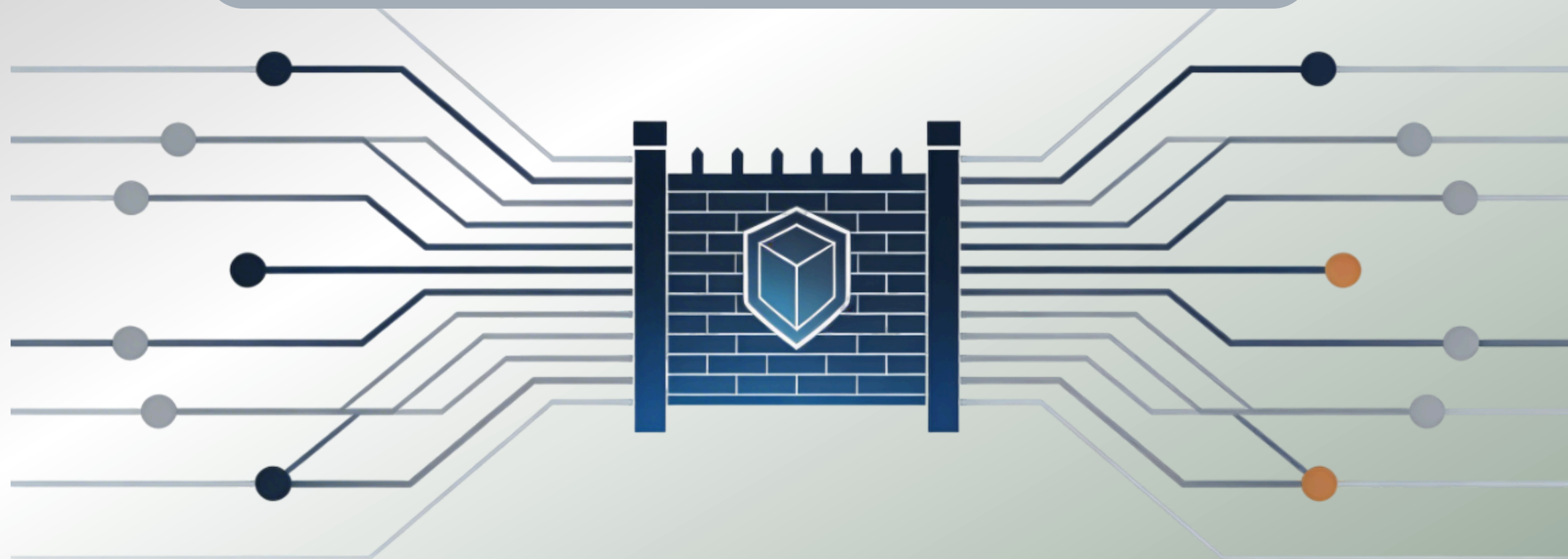
Objetivos específicos

Analizar los logs del firewall de la empresa

Detectar patrones de tráfico y posibles riesgos

Proponer ajustes de reglas más seguras

Documentar la metodología seguida para repetir el análisis



ENTORNO Y DATOS DISPONIBLES

Entorno real: firewall de la empresa gestionado con Panorama (Palo Alto)



Datos usados: exportación de logs de una regla a hoja de cálculo

src_ip	dns_src_ip	dest_ip	dest_port	app	action	count	total_bytes	Propos
10.216.102.2		20.79.86.202	443	incomplete	allowed	29991	5250840	
10.216.100.5		20.79.86.202	443	incomplete	allowed	23892	5235930	
10.216.100.3		20.79.86.202	443	incomplete	allowed	29871	5230260	
10.216.123		20.79.86.202	443	incomplete	allowed	29686	5194840	
10.216.127		20.79.86.202	443	incomplete	allowed	29686	3116330	
10.216.100.2		20.79.86.202	443	incomplete	allowed	23255	5113010	
10.216.120		20.79.86.202	443	incomplete	allowed	27999	4896990	
10.216.117		20.79.86.202	443	incomplete	allowed	26590	4660740	
10.216.7.5		20.79.86.202	443	incomplete	allowed	23322	4086390	
10.216.44.48		20.79.86.202	443	incomplete	allowed	21854	3816890	
10.216.102.2		10.125.52.247	443	incomplete	allowed	19350	5135130	
10.220.8.230		20.79.86.202	443	incomplete	allowed	19318	3382890	
10.216.138.6		20.79.86.202	443	incomplete	allowed	19312	3375750	
10.216.124.253		20.79.86.202	443	incomplete	allowed	19198	3360700	
10.216.118.33		20.79.86.202	443	incomplete	allowed	19080	3334870	
10.216.118.36		20.79.86.202	443	incomplete	allowed	19037	3329690	
10.220.8.253		20.79.86.202	443	incomplete	allowed	18991	3320800	
10.216.138.3		20.79.86.202	443	incomplete	allowed	18901	3307990	
10.216.24.221		20.79.86.202	443	incomplete	allowed	18803	3289650	
10.220.8.254		20.79.86.202	443	incomplete	allowed	18618	3255420	
10.216.24.221		10.123.2.47	443	incomplete	allowed	17688	4761120	
10.220.128.92		20.79.86.202	443	incomplete	allowed	15287	2673440	
10.220.128.91		20.79.86.202	443	incomplete	allowed	15187	2657130	
10.220.128.93		20.79.86.202	443	incomplete	allowed	15187	2654470	
10.216.44.56		20.79.86.202	443	incomplete	allowed	4604	805700	
10.216.64.4		57.128.101.78	443	incomplete	allowed	3564	624750	
10.216.64.4		57.128.101.74	443	incomplete	allowed	3545	620270	
10.216.64.4		57.128.101.75	443	incomplete	allowed	3507	614040	
10.216.64.4		57.128.101.77	443	incomplete	allowed	3385	591430	
10.220.9.125		20.79.86.202	443	incomplete	allowed	3298	577360	
10.220.9.123		20.79.86.202	443	incomplete	allowed	3249	568470	
10.220.9.124		20.79.86.202	443	incomplete	allowed	3056	535010	
10.216.124		150.171.28.11	443	incomplete	allowed	2772	952538	
10.216.124		150.171.27.11	443	incomplete	allowed	2756	946832	
10.216.64.4		57.129.19.230	443	incomplete	allowed	2634	462000	
10.216.64.4		57.129.37.75	443	incomplete	allowed	2600	456470	
10.216.64.4		57.129.37.28	443	incomplete	allowed	2593	453880	
10.216.117		44.55.123.83	443	incomplete	allowed	2410	421120	
10.216.117		44.55.123.82	443	incomplete	allowed	2408	421400	
10.216.117		44.55.123.75	443	incomplete	allowed	2402	419930	
10.216.116.6		44.55.123.75	443	incomplete	allowed	2349	412020	
10.216.116.6		44.55.123.83	443	incomplete	allowed	2343	411180	
10.216.116.6		44.55.123.82	443	incomplete	allowed	2332	408240	
10.216.24.221		44.55.123.82	443	incomplete	allowed	2222	389480	
10.220.64.6		44.55.123.74	443	incomplete	allowed	2222	389690	
10.216.116.3		44.55.123.82	443	incomplete	allowed	2217	389130	
10.220.169		44.55.123.74	443	incomplete	allowed	2211	385770	
10.216.8.151		44.55.123.83	443	incomplete	allowed	2210	387170	

Campos clave analizados: src_ip, dest_ip, puerto, aplicación, proveedor, app..

Rule #1	Network name	dns_src_ip	dest_ip	dns_dest_ip
Sumarized source	INDUS_UK_1		20.79.86.202	Azure
10.216.10127	INDUS_2701_FL_SPS			
10.216.100.0/26	INDUS_BRD_ETS			
10.220.8.0/24	INDUS_BRD_STS			
10.216.44.0/26	INDUS_BRD_ETS_LAN			
10.220.8.0/25	INDUS_BRD_ETS_LAN			
10.220.128.64/27	INDUS_BRD_ETS_STS			
10.216.138.6	nx003-ta8qem.ukmaten.idnx.corp			
10.216.138.3	nx003-ta8.ukmaten.idnx.corp			
10.216.118.33	nx037-ta4.ukmaten.idnx.corp			
10.216.118.36	nx037-ta4qem.ukmaten.idnx.corp			
10.216.102.2	fidw402043255.nor.eu.altrex.lab			
10.216.38.122	chdw402045383.nor.eu.altrex.lab			
10.216.124.221	chwa402038563.eu.altrex.lab			
10.216.24.221	finw402030767.nor.eu.altrex.lab			
10.216.25.16				
10.216.7.5				
10.220.3.4				
Rule #2	Network name	dns_src_ip	dest_ip	dns_dest_ip
src_ip		chmw402030982.nor.eu.altrex.lab	10.55.123.83	otom-ut-i-900-p.nor.eu.altrex.lab
10.216.117			10.55.123.82	nexa-vp2.eu.altrex.lab
10.216.120			10.55.123.75	x300-db-v.altrex.lab
10.216.123		addchwa402036957.eu.altrex.lab	10.55.123.74	taloon-2b52-i.nexa
10.216.126		vhw-i0v04i2kcoj.eu.altrex.lab		
10.216.127		chwa402001636.eu.altrex.lab		
10.216.130		addchwa402037936.eu.altrex.lab		
10.216.1130		finw400048622.eu.altrex.lab		
10.216.1131		finw400048623.nor.eu.altrex.lab		
10.216.2.190		finw400049230.eu.altrex.lab		
10.216.4.195		uk1-gst02preset.ukmaten.idnx.corp		
10.216.8.150		bx128-paint-m.ukmaten.idnx.corp		
10.216.8.151		bx128-paint-s.ukmaten.idnx.corp		
10.216.24.221		chmw402045383.eu.altrex.lab		
10.216.44.61		uk1-ets01.ukmaten.idnx.corp		
10.216.100.4		fidw40202203032.nor.eu.altrex.lab		
10.216.102.2		fidw402043255.nor.eu.altrex.lab		
10.216.116.3		chwa400035533.nor.eu.altrex.lab		
10.216.116.6		chwa400043653.nor.eu.altrex.lab		
10.220.167		uk1-a350preset.ukmaten.idnx.corp		
10.220.169		uk1-fs03.ukmaten.idnx.corp		
10.220.3.4		finw402030767.nor.eu.altrex.lab		
10.220.64.5		bx037-preset1.ukmaten.idnx.corp		
10.220.64.6		bx037-preset2.ukmaten.idnx.corp		
10.220.64.9		uk1-asapreset.ukmaten.idnx.corp		



El análisis se ha realizado sobre datos anonimizados para preservar la confidencialidad del entorno

REGLA DE PARTIDA

	NAME	LOCATION	TAGS	TYPE	ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE	APPLICATION	SERVICE	ACTION	PROFILE
380	SC_39154	fwindus-uk	none	universal	 indus1  indus2  indus3  indus4  indus5	 INDUS_CAMPUS_UK	any	any	 LAN	any	any	any	 TCP_443	 Allow	



- Se seleccionó la regla SC_39154 como caso de estudio
- Permitía tráfico TCP_443 desde INDUS_CAMPUS_UK hacia destino any.
- Su configuración era amplia, con criterios muy generales (any)
- Por su alta permisividad, resultaba adecuada para analizar su uso real mediante logs.
- El objetivo era comprobar si podía ajustarse siguiendo el principio de mínimo privilegio

METODOLOGÍA / FLUJO DE TRABAJO

Revisión inicial de la estructura de los logs



Filtrado, agrupación y análisis de patrones en Excel



Identificación de reglas candidatas a optimización



Documentación de cada regla y su justificación



Como apoyo al análisis manual en Excel, se desarrolló una pequeña prueba de concepto en Python con pandas para automatizar parte del filtrado de logs.

DISEÑO TÉCNICO

Redes internas de la empresa



Firewall perimetral
(Palo Alto)



Salida hacia Internet y
proveedores cloud



Destinos típicos: AWS, Azure,
Google Cloud, Akamai CDN



ESQUEMA DE CLASIFICACIÓN

Tipos de destino



y otros proveedores
cloud/CDN..

Patrones de tráfico analizados

Muchos orígenes



Un destino

(Servicio
centralizado/proveedor)

Un origen



Muchos destinos

(Equipo que accede a
múltiples servicios)

Subred interna



Proveedor concreto

(Servicio corporativo
en la nube)

Host



Host

(comunicación
específica entre dos
equipos)

REGLAS PROPUESTA Y AUTOMATIZACIÓN PARCIAL CON PYTHON

Rule #3					
src_ip	Network name	dns_src_ip	dest_ip	dns_dest_ip	dest_port
10.216.64.4		wot-bx-b196-maj-hmj-1.nor.eu.altrex.lab	57.128.101.78	AnyDesk	443
			57.128.101.74		
			57.128.101.75		
			57.128.101.77		
			57.129.19.230		
			57.129.37.75		
			57.129.37.28		
			92.223.88.7		
			92.223.88.41		
			92.223.88.232		
			195.181.174.174		
			195.181.174.173		
			195.181.174.167		
			185.229.191.44		
			185.229.191.39		
			185.229.190.236		
			23.50.131.90	Akamai Technologies (CDN)	
			23.50.131.88		
			23.50.131.86		
			23.50.131.75		
			23.48.23.47		
			23.48.23.14		
			23.33.90.79		
			23.32.238.161		
			23.32.238.160		
			23.213.161.9		
			23.213.161.5		
			23.213.161.29		
			23.213.161.28		
			23.213.161.27		
			23.213.161.26		
			23.213.161.24		
			23.213.161.23		
			23.213.161.19		
			23.213.161.16		
			23.213.161.12		
			23.213.161.10		
			92.123.104.63		
			92.123.104.24		
			96.16.122.83		
			95.101.137.83		
			95.101.137.71		
			95.100.133.77		
			2.21.143.29		
			2.16.241.205		
			2.16.168.106		
			184.86.251.29		
			184.25.50.192		
			13.89.179.10	Azure	
			13.107.246.45		
			13.107.246.42		
			13.107.213.45		
			13.107.213.42		
			52.109.89.18	Microsoft	

UN ORIGEN HACIA MUCHOS DESTINOS

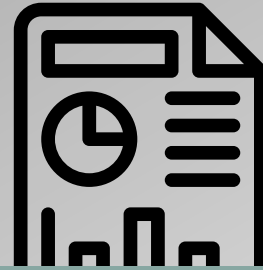
Se observa un único origen interno, el host 10.216.64.4, con conexiones HTTPS hacia numerosos destinos externos distintos.

Entre esos destinos aparecen servicios variados, como plataformas externas, CDN y proveedores cloud, todos concentrados en el puerto 443.

Este patrón se tomó como caso representativo para la automatización,A partir de él, se desarrolló un script en Python con pandas para filtrar los logs por origen y extraer los destinos observados

Esto permite pasar de una revisión manual a una automatización parcial, repetible y verificable

RESULTADOS Y BENEFICIOS



RESULTADOS

Predominio de tráfico hacia cloud y CDN.

Identificación de hosts clave y subredes con accesos amplios.

Detección de patrones repetitivos y comunicaciones internas específicas.



BENEFICIOS

Política más clara y resumida.

Mejor base para mínimo privilegio.

Más facilidad para revisar, auditar y endurecer reglas en el futuro.

LIMITACIONES Y TRABAJOS FUTUROS

LIMITACIONES

Solo un periodo de estudio.

El proceso ha sido principalmente manual en Excel

Sin análisis en tiempo real.

TRABAJOS FUTUROS

Ampliar la automatización parcial ya validada con Python

Integrar con logs centralizados / SIEM.

Repetir revisiones periódicas.

CONCLUSIÓN Y CIERRE

CONCLUSIÓN

De un Excel enorme y sin contexto a una propuesta de reglas más clara y justificada

APRENDIZAJE

Interpretar logs reales.

Detectar patrones útiles.

Justificar decisiones técnicas con evidencias.

Entender mejor la relación entre red, seguridad y documentación técnica

GRACIAS